

COURSEWORK 1: SET EXERCISES - PCAP ANALYSIS

Github Link: <https://github.com/Mattrfish/COMP3010-SecOps-and-Incident-Management.git>

Youtube Walkthrough Link: https://youtu.be/ZFjp_QCV8sc

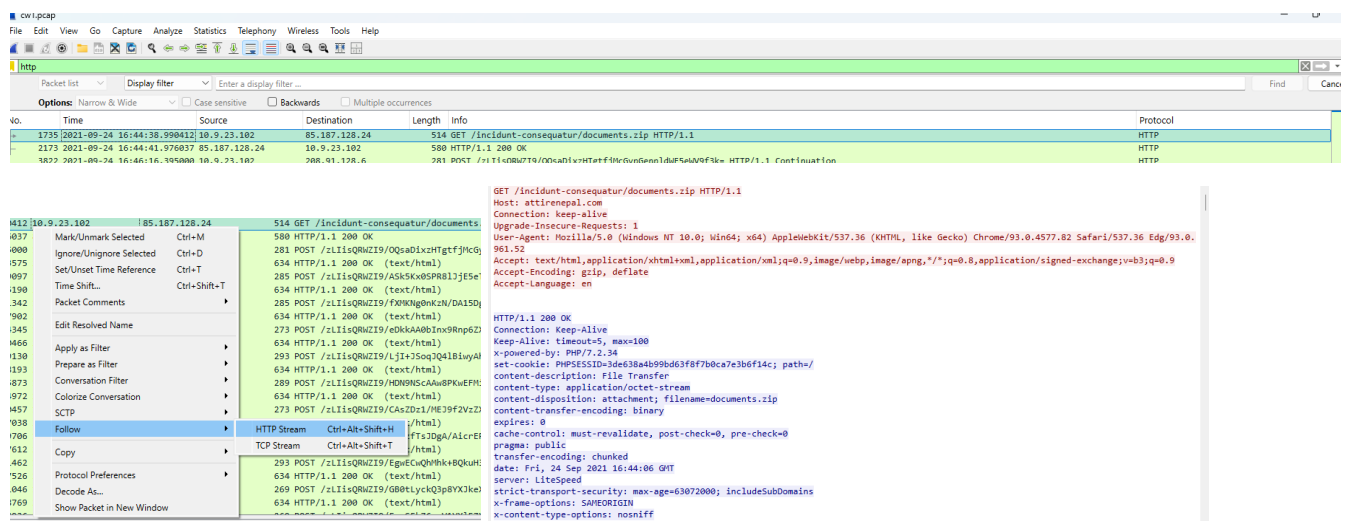
INTRODUCTION

This report presents a detailed analysis of a provided PCAP file to investigate a suspected network intrusion. The primary objective was to reconstruct the cyber kill chain by identifying the infected host, determining the infection vector, classifying the attack, and extracting key Indicators of Compromise (IOCs) to facilitate containment and future prevention.

This report is structured as follows: The methodology section outlines the tools and techniques used and how they were applied to investigate the intrusion. The results section presents the key findings from the PCAP analysis, supported by evidence and screenshots. Finally, the conclusion summarises the findings, discusses prevention strategies to mitigate similar incidents in the future, and reflects on any challenges encountered during the investigation.

METHODOLOGY

The investigation was conducted using Wireshark, as it is one of the most effective open source tools for packet-level network traffic analysis. The analytical process was phased to methodically trace the attack chain. The process began with an initial review of the entire capture to provide context on overall network activity and identify anomalous traffic patterns. For the initial infection analysis, the http display filter was used to isolate and inspect all clear-web HTTP traffic; the "Follow HTTP Stream" function was critical for reconstructing the content of communications between the victim and attacker-controlled servers, allowing for the identification of downloaded files without executing potentially malicious content.



To investigate post-infection and C2 activity, filters such as `tls.handshake.type == 1` (to find ClientHello packets) and specific time frames (`frame.time >= "2021-09-24 16:45:11" && frame.time <= "2021-09-24 16:45:30"`) were applied to analyse encrypted HTTPS traffic, which allowed me to identify domains involved in the attack even without decrypting the payload. The "Statistics > Conversations" feature was used to identify endpoints with sustained, high-volume communication, a key indicator of Command and Control (C2) beaconing. Finally, filters for specific protocols (e.g., dns and smtp) were used to identify data exfiltration channels and credential harvesting attempts.

The image shows two screenshots of the Wireshark network protocol analyzer. The top screenshot displays the 'Packet list' pane with a filter `tls.handshake.type == 1 && frame.time_epoch >= 1632501911 && frame.time_epoch <= 1632501930`. It lists several TLS ClientHello packets from 10.9.23.102 to various destinations. The bottom screenshot shows the 'Conversations' pane for 'cw1.pcap', displaying a table of communication statistics between 10.9.23.102 and other hosts. Below this, a packet list is filtered with `dns.a == 185.106.96.158`, showing a DNS standard query response.

No.	Time	Source	Destination	Length	Info	Protocol
2427	2021-09-24 16:45:11.840716	10.9.23.102	148.72.192.206	247	Client Hello (SNI=finejewels.com.au)	TLSv1.2
2646	2021-09-24 16:45:17.228469	10.9.23.102	13.69.109.131	242	Client Hello (SNI=self.events.data.microsoft.com)	TLSv1.2
2909	2021-09-24 16:45:20.389994	10.9.23.102	20.54.36.229	238	Client Hello (SNI=client.wms.windows.com)	TLSv1.2
3009	2021-09-24 16:45:21.314032	10.9.23.102	210.245.90.247	244	Client Hello (SNI=thietbiagt.com)	TLSv1.2
3229	2021-09-24 16:45:25.731116	10.9.23.102	148.72.53.144	247	Client Hello (SNI=new.americold.com)	TLSv1.2

Address A	Address B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A
10.9.23.102	85.187.128.24	2	1 kB	34	225	0.89%	1	514 bytes	1	580 bytes
10.9.23.102	104.83.124.33	4	806 bytes	50	25	16.00%	2	338 bytes	2	468 bytes
10.9.23.102	185.106.96.158	152	71 kB	57	1,973	7.70%	76	43 kB	76	28 kB
10.9.23.102	185.125.204.174	1	2 kB	49	2,923	0.03%	0	0 bytes	1	2 kB
10.9.23.102	208.91.128.6	52	24 kB	46	244	21.31%	26	7 kB	26	17 kB

No.	Time	Source	Destination	Length	Info
6511	2021-09-24 16:55:10.808336	10.9.23.5	10.9.23.102	90	Standard query response 0xe5da A survmeter.live A 185.106.96.158

RESULTS

Initial Infection Analysis

The analysis successfully reconstructed a multi-stage attack, culminating in the full compromise of an internal host and attempted data exfiltration. The incident began at 2021-09-24 16:44:38 UTC when the internal host 10.9.23.102 initiated an HTTP connection to the malicious IP 85.187.128.24; the host downloaded a file named `documents.zip` from the domain `attirenepal.com`. Inside the ZIP archive was a single file, `chart-1530076591.xls`. This strongly implies the attack relied on a Microsoft Excel Macro as the initial execution mechanism. The serving infrastructure, LiteSpeed/7.2.34, while legitimate, was likely a compromised web server.

The image shows a screenshot of the Wireshark 'Packet list' pane with a filter `http`. It displays three HTTP packets: a GET request for `/incident-consequatur/documents.zip`, an HTTP 200 OK response, and an HTTP 1.1 continuation.

No.	Time	Source	Destination	Length	Info	Protocol
1735	2021-09-24 16:44:38.990412	10.9.23.102	85.187.128.24	514	GET /incident-consequatur/documents.zip HTTP/1.1	HTTP
2173	2021-09-24 16:44:41.976037	85.187.128.24	10.9.23.102	580	HTTP/1.1 200 OK	HTTP
3022	2021-09-24 16:46:16.395000	10.9.23.102	208.91.128.6	281	POST /zL1isQRWZ19/OQsaD1xzHgtfJlCdyppgenlId#5eW9f3k= HTTP/1.1 Continuation	HTTP

```

GET /incidunt-consequatur/documents.zip HTTP/1.1
Host: attirenepal.com
Connection: Keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.457
961.52
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/si
Accept-Encoding: gzip, deflate
Accept-Language: en

HTTP/1.1 200 OK
Connection: Keep-Alive
Keep-Alive: timeout=5, max=100
x-powered-by: PHP/7.2.34
set-cookie: PHPSESSID=3de638a4b99bd63f8f7b0ca7e3b6f14c; path=/
content-description: File Transfer
content-type: application/octet-stream
content-disposition: attachment; filename=documents.zip
content-transfer-encoding: binary
expires: 0
cache-control: must-revalidate, post-check=0, pre-check=0
pragma: public
transfer-encoding: chunked
date: Fri, 24 Sep 2021 16:44:06 GMT
server: LiteSpeed
strict-transport-security: max-age=63072000; includeSubDomains
x-frame-options: SAMEORIGIN
x-content-type-options: nosniff

10000
PK.....d8S.a../.....chart-1530076591.xlsUT....Ma..Maux.....[w\...>..[.U@.X@,..K.&.

```

Following the initial download, the victim host immediately began communicating with other suspicious domains over HTTPS. Analysis of TLS handshakes between 16:45:11 and 16:45:30 UTC revealed connections to three additional domains: finejewels.com.au, thietbiagt.com, and new.americold.com; the SSL certificate for finejewels.com.au was issued by the GoDaddy Root Certificate Authority to evade detection by making malicious traffic appear legitimate.

tls && frame.time_epoch >= 1632501881.976037000 && frame.time_epoch <= 1632501976.395000000					
Packet list Display filter Enter a display filter ...					
Options: Narrow & Wide ☐ Case sensitive ☐ Backwards ☐ Multiple occurrences					
No.	Time	Source	Destination	Length	Info
2234	2021-09-24 16:44:50.507377	23.220.255.44	10.9.23.102	85	Encrypted Alert
2238	2021-09-24 16:44:53.215656	104.120.111.248	10.9.23.102	85	Encrypted Alert
2286	2021-09-24 16:45:04.077184	10.9.23.102	2.20.205.205	262	Client Hello (SNI=storeedgefd.dsx.mp.microsoft.com)
2288	2021-09-24 16:45:04.240646	2.20.205.205	10.9.23.102	1402	Server Hello
2293	2021-09-24 16:45:04.401676	2.20.205.205	10.9.23.102	419	Certificate, Server Key Exchange, Server Hello Done
2295	2021-09-24 16:45:04.408258	10.9.23.102	2.20.205.205	180	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
2298	2021-09-24 16:45:04.421151	10.9.23.102	2.20.205.205	1127	Application Data
2301	2021-09-24 16:45:04.576133	2.20.205.205	10.9.23.102	328	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
2303	2021-09-24 16:45:04.742197	2.20.205.205	10.9.23.102	841	Application Data
2384	2021-09-24 16:45:07.825650	10.9.23.102	13.107.42.16	242	Client Hello (SNI=config.edge.skype.com)
2393	2021-09-24 16:45:07.993804	13.107.42.16	10.9.23.102	210	Server Hello, Certificate, Certificate Status, Server Key Exchange, Server Hello Done
2395	2021-09-24 16:45:07.998016	10.9.23.102	13.107.42.16	212	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message

tls.handshake.type == 1 && frame.time_epoch >= 1632501911 && frame.time_epoch <= 1632501930					
Packet list Display filter Enter a display filter ...					
Options: Narrow & Wide ☐ Case sensitive ☐ Backwards ☐ Multiple occurrences					
No.	Time	Source	Destination	Length	Info
2427	2021-09-24 16:45:11.840716	10.9.23.102	148.72.192.206	247	Client Hello (SNI=finejewels.com.au)
2646	2021-09-24 16:45:17.228469	10.9.23.102	13.69.109.131	242	Client Hello (SNI=self.events.data.microsoft.com)
2909	2021-09-24 16:45:20.389994	10.9.23.102	20.54.36.229	238	Client Hello (SNI=client.wns.windows.com)
3009	2021-09-24 16:45:21.314012	10.9.23.102	210.245.90.247	244	Client Hello (SNI=thietbiagt.com)
3229	2021-09-24 16:45:25.731116	10.9.23.102	148.72.53.144	247	Client Hello (SNI=new.americold.com)

ip.addr == 148.72.192.206

Packet list | Display filter | Enter a display filter ...

Options: Narrow & Wide | Case sensitive | Backwards | Multiple occurrences

No.	Time	Source	Destination	Length	Info
2424	2021-09-24 16:45:11.441665	10.9.23.102	148.72.192.206	66	63368 → 443 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM=1
2425	2021-09-24 16:45:11.838177	148.72.192.206	10.9.23.102	58	443 → 63368 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
2426	2021-09-24 16:45:11.838807	10.9.23.102	148.72.192.206	54	63368 → 443 [ACK] Seq=1 Ack=1 Win=65535 Len=0
2427	2021-09-24 16:45:11.840716	10.9.23.102	148.72.192.206	247	Client Hello (SNI=finejewels.com.au)
2428	2021-09-24 16:45:11.840849	148.72.192.206	10.9.23.102	54	443 → 63368 [ACK] Seq=1 Ack=194 Win=64240 Len=0
2433	2021-09-24 16:45:12.322204	148.72.192.206	10.9.23.102	1414	Server Hello
2434	2021-09-24 16:45:12.322435	10.9.23.102	148.72.192.206	54	63368 → 443 [ACK] Seq=194 Ack=1361 Win=65535 Len=0
2435	2021-09-24 16:45:12.322667	148.72.192.206	10.9.23.102	1514	443 → 63368 [ACK] Seq=1361 Ack=194 Win=64240 Len=1460 [TCP PDU retransmission]
2436	2021-09-24 16:45:12.322676	148.72.192.206	10.9.23.102	618	Certificate, Server Key Exchange, Server Hello Done
2437	2021-09-24 16:45:12.322846	10.9.23.102	148.72.192.206	54	63368 → 443 [ACK] Seq=194 Ack=3385 Win=65535 Len=0
2438	2021-09-24 16:45:12.328971	10.9.23.102	148.72.192.206	147	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
2439	2021-09-24 16:45:12.329082	148.72.192.206	10.9.23.102	54	443 → 63368 [ACK] Seq=3385 Ack=287 Win=64240 Len=0
2440	2021-09-24 16:45:12.827837	148.72.192.206	10.9.23.102	401	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
2441	2021-09-24 16:45:12.828109	10.9.23.102	148.72.192.206	54	63368 → 443 [ACK] Seq=287 Ack=3732 Win=65535 Len=0
2442	2021-09-24 16:45:12.832334	10.9.23.102	148.72.192.206	141	Application Data
2443	2021-09-24 16:45:12.832452	148.72.192.206	10.9.23.102	54	443 → 63368 [ACK] Seq=3732 Ack=374 Win=64240 Len=0
2444	2021-09-24 16:45:12.832454	10.9.23.102	148.72.192.206	92	Application Data
2445	2021-09-24 16:45:12.832514	148.72.192.206	10.9.23.102	54	443 → 63368 [ACK] Seq=3732 Ack=412 Win=64240 Len=0
2446	2021-09-24 16:45:12.832641	10.9.23.102	148.72.192.206	204	Application Data
2447	2021-09-24 16:45:12.832709	148.72.192.206	10.9.23.102	54	443 → 63368 [ACK] Seq=3732 Ack=562 Win=64240 Len=0
2448	2021-09-24 16:45:13.242973	148.72.192.206	10.9.23.102	92	Application Data
2449	2021-09-24 16:45:13.243411	10.9.23.102	148.72.192.206	54	63368 → 443 [ACK] Seq=562 Ack=3770 Win=65535 Len=0
2450	2021-09-24 16:45:14.328943	148.72.192.206	10.9.23.102	1514	Application Data
2451	2021-09-24 16:45:14.328981	148.72.192.206	10.9.23.102	1314	Application Data

Certificate Length: 1236

▼ Certificate [...]: 308204d0308203b8a003020102020107300d06092a864886f70d01010b0500308183310b3

▼ signedCertificate

version: v3 (2)

serialNumber: 0x07

signature (sha256WithRSAEncryption)

issuer: rdnSequence (0)

▼ rdnSequence: 5 items (id-at-commonName=Go Daddy Root Certificate Authority - G2, id-at-countryName=US)

▼ rdnSequence item: 1 item (id-at-countryName=US)

▼ rdnSequence item: 1 item (id-at-stateOrProvinceName=Arizona)

▼ rdnSequence item: 1 item (id-at-localityName=Scottsdale)

▼ rdnSequence item: 1 item (id-at-organizationName=GoDaddy.com, Inc.)

▼ rdnSequence item: 1 item (id-at-commonName=Go Daddy Root Certificate Authority)

Post-Infection & C2 Beaconsing Analysis

Post-infection analysis revealed persistent POST requests to a suspicious domain. The "Statistics > Conversations" view revealed two additional external IPs, 185.106.96.158 and 185.125.204.174, exhibiting high, sustained packet counts with the victim indicating C2. The regularity of these requests, occurring at consistent intervals, is a classic sign of automated malware like Cobalt Strike Beacon, which uses these callbacks to await further instructions.

http.request.method == POST && ip.addr == 208.91.128.6

No.	Time	Source	Destination	Length	Info
3822	2021-09-24 16:46:16.395008	10.9.23.102	208.91.128.6	281	POST /zLlIsQRWZi9/OQsaDixzHTgtfjMcGypGenldwF5eW9f3k= HTTP/1.1 Continuation
3908	2021-09-24 16:46:41.509097	10.9.23.102	208.91.128.6	285	POST /zLlIsQRWZi9/ASK5Kx0SPR81jE5eTg9GkN6GfYzHl/YXp6eQ== HTTP/1.1 Continuation
3996	2021-09-24 16:47:06.571342	10.9.23.102	208.91.128.6	285	POST /zLlIsQRWZi9/FXMKNg0nKzN/DA150gg8I0N6GfYzHl/YXp6eQ== HTTP/1.1 Continuation
4006	2021-09-24 16:47:31.584345	10.9.23.102	208.91.128.6	273	POST /zLlIsQRWZi9/eDkAAAbInx9Rnp6ZVXheXl1fX95 HTTP/1.1 Continuation
4017	2021-09-24 16:47:56.779130	10.9.23.102	208.91.128.6	293	POST /zLlIsQRWZi9/Lji+J5oqJQ41BiwyAhR7KngvHgoPKBhfntkcmJ9eGR6FH0= HTTP/1.1 Continuation
4027	2021-09-24 16:48:21.805873	10.9.23.102	208.91.128.6	289	POST /zLlIsQRWZi9/H0N9N5CAAw8PKwEFNi0/JTISPEZ6emV1YX15ZX1/eQ== HTTP/1.1 Continuation
4037	2021-09-24 16:48:46.850457	10.9.23.102	208.91.128.6	273	POST /zLlIsQRWZi9/CasDz21/MEJ9f2Vz2V58Zxt7fg== HTTP/1.1 Continuation
4046	2021-09-24 16:49:11.959706	10.9.23.102	208.91.128.6	285	POST /zLlIsQRWZi9/DCLfztJdga/AicrRgXCHsERX57ZH3ifXhkenx9 HTTP/1.1 Continuation

Wireshark · Conversations · cw1.pcap

Conversation Settings

☐ Name resolution

☐ Absolute start time

☒ Limit to display filter

2
EX
Fi

Ethernet · 1	IPv4 · 5	IPv6	TCP · 106	UDP
Address A	Address B	Packets	Bytes	Stream ID
10.9.23.102	85.187.128.24	2	1 kB	34
10.9.23.102	104.83.124.33	4	806 bytes	50
10.9.23.102	185.106.96.158	152	71 kB	57
10.9.23.102	185.125.204.174	1	2 kB	49
10.9.23.102	208.91.128.6	52	24 kB	46

http.request.method == GET && ip.addr == 185.106.96.158

No.	Time	Source	Destination	Length	Info
6326	2021-09-24 16:55:08.593562	10.9.23.102	185.106.96.158	306	GET /spfooh/cacerts.cr1 HTTP/1.1
6516	2021-09-24 16:55:11.044112	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
7179	2021-09-24 16:55:52.531330	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
10285	2021-09-24 16:56:49.641455	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
10479	2021-09-24 16:56:53.484082	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
10542	2021-09-24 16:56:58.607463	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
10643	2021-09-24 16:57:02.872726	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13196	2021-09-24 16:57:15.329440	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13216	2021-09-24 16:57:21.410344	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13230	2021-09-24 16:57:26.122480	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13239	2021-09-24 16:57:31.037009	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13324	2021-09-24 16:57:35.440084	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13385	2021-09-24 16:57:40.878644	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13396	2021-09-24 16:57:45.271630	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13405	2021-09-24 16:57:50.369462	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf
13416	2021-09-24 16:57:55.718813	10.9.23.102	185.106.96.158	569	GET /gscp./oapnlpncnigpfpfmgdhahbbbjgicmfgekplacgedhacmaghehdcdaaajhknogblpjbmiebdchniabihjblgf

ip.addr == 185.125.204.174					
No.	Time	Source	Destination	Length	Info
4216	2021-09-24 16:53:24.084722	10.9.23.102	185.125.204.174	66	63410 → 8080 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
4217	2021-09-24 16:53:24.246485	185.125.204.174	10.9.23.102	58	8080 → 63410 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
4218	2021-09-24 16:53:24.246766	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=1 Ack=1 Win=65535 Len=0
4219	2021-09-24 16:53:24.251794	10.9.23.102	185.125.204.174	203	63410 → 8080 [PSH, ACK] Seq=1 Ack=1 Win=65535 Len=149
4220	2021-09-24 16:53:24.251887	185.125.204.174	10.9.23.102	54	8080 → 63410 [ACK] Seq=1 Ack=150 Win=64240 Len=0
4221	2021-09-24 16:53:24.425150	185.125.204.174	10.9.23.102	144	8080 → 63410 [PSH, ACK] Seq=1 Ack=150 Win=64240 Len=90
4222	2021-09-24 16:53:24.425395	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=150 Ack=91 Win=65535 Len=0
4223	2021-09-24 16:53:24.426901	185.125.204.174	10.9.23.102	1402	8080 → 63410 [PSH, ACK] Seq=91 Ack=150 Win=64240 Len=1348
4224	2021-09-24 16:53:24.427078	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=150 Ack=1439 Win=65535 Len=0
4225	2021-09-24 16:53:24.586143	185.125.204.174	10.9.23.102	367	8080 → 63410 [PSH, ACK] Seq=1439 Ack=150 Win=64240 Len=313
4226	2021-09-24 16:53:24.586367	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=150 Ack=1752 Win=65535 Len=0
4249	2021-09-24 16:53:26.609487	10.9.23.102	185.125.204.174	147	63410 → 8080 [PSH, ACK] Seq=150 Ack=1752 Win=65535 Len=93
4250	2021-09-24 16:53:26.609580	185.125.204.174	10.9.23.102	54	8080 → 63410 [ACK] Seq=1752 Ack=243 Win=64240 Len=0
4251	2021-09-24 16:53:26.788927	185.125.204.174	10.9.23.102	60	8080 → 63410 [PSH, ACK] Seq=1752 Ack=243 Win=64240 Len=6
4252	2021-09-24 16:53:26.781179	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=243 Ack=1758 Win=65535 Len=0
4253	2021-09-24 16:53:26.950298	185.125.204.174	10.9.23.102	99	8080 → 63410 [PSH, ACK] Seq=1758 Ack=243 Win=64240 Len=45
4254	2021-09-24 16:53:26.950521	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=243 Ack=1803 Win=65535 Len=0
4255	2021-09-24 16:53:26.952886	10.9.23.102	185.125.204.174	449	63410 → 8080 [PSH, ACK] Seq=243 Ack=1803 Win=65535 Len=395
4256	2021-09-24 16:53:26.952958	185.125.204.174	10.9.23.102	54	8080 → 63410 [ACK] Seq=1803 Ack=638 Win=64240 Len=0
4257	2021-09-24 16:53:27.126606	185.125.204.174	10.9.23.102	353	8080 → 63410 [PSH, ACK] Seq=1803 Ack=638 Win=64240 Len=299
4258	2021-09-24 16:53:27.126872	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=638 Ack=2102 Win=65535 Len=0
4259	2021-09-24 16:53:27.127769	185.125.204.174	10.9.23.102	1514	8080 → 63410 [ACK] Seq=2102 Ack=638 Win=64240 Len=1460
4260	2021-09-24 16:53:27.127780	185.125.204.174	10.9.23.102	1290	8080 → 63410 [PSH, ACK] Seq=3562 Ack=638 Win=64240 Len=1236
4261	2021-09-24 16:53:27.128171	10.9.23.102	185.125.204.174	54	63410 → 8080 [ACK] Seq=638 Ack=4798 Win=65535 Len=0

Traffic to the first C2 server (185.106.96.158) used the HTTP Host header `ocsp.verisign.com\r\n`. This is a clear attempt at domain impersonation, designed to disguise malicious C2 traffic as legitimate communication, thereby bypassing simple security controls that whitelist trusted domains. DNS analysis mapped these IPs to their domains: `survmeter.live` and `securitybusinpuuff.com`.

```
GET /spfooh/cacerts.crl HTTP/1.1
Host: ocsp.verisign.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; W
.4093.147
Connection: Close
Cache-Control: no-cache
```

```
HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:55:08 GMT
Server: nginx
Content-Length: 210002
Keep-Alive: timeout=20, max=200
Connection: close
Content-Type: image/gif
```

dns.a == 185.106.96.158					
No.	Time	Source	Destination	Length	Info
6511	2021-09-24 16:55:10.808336	10.9.23.5	10.9.23.102	90	Standard query response 0xe5da A survmeter.live A 185.106.96.158

dns.a == 185.125.204.174					
No.	Time	Source	Destination	Length	Info
4494	2021-09-24 16:53:28.005596	10.9.23.5	10.9.23.102	97	Standard query response 0xc042 A securitybusinpuuff.com A 185.125.204.174

Data Exfiltration and Reconnaissance

A third domain, `maldivehost.net`, was identified for the frequent POST requests from the victim. This activity is characteristic of data exfiltration. The first packet sent to this server contained a 281-byte payload beginning with the unique identifier `zLIisQRWZi9`. This string likely represents a victim identifier or session token, allowing the attacker to correlate exfiltrated data with a specific machine. The server was running Apache/2.4.49 (cPanel), a common web hosting configuration, suggesting the attacker may have compromised a legitimate server for their exfiltration.

dns.a == 208.91.128.6					
No.	Time	Source	Destination	Length	Info
3806	2021-09-24 16:46:16.135691	10.9.23.5	10.9.23.102	91	Standard query response 0xf236 A maldivehost.net A 208.91.128.6
10003	2021-09-24 16:56:18.942514	10.9.23.5	10.9.23.102	91	Standard query response 0x9cfc A maldivehost.net A 208.91.128.6

http.host == maldivehost.net					
No.	Time	Source	Destination	Length	Info
3822	2021-09-24 16:46:16.395000	10.9.23.102	208.91.128.6	281	POST /zLIisQRWZi9/OQsaDixzHTgtfjMcGypGenpldwF5ehV9f3k= HTTP/1.1 Continuation
3908	2021-09-24 16:46:41.509097	10.9.23.102	208.91.128.6	285	POST /zLIisQRWZi9/Ask5Kx0SPR8l3jE5eTg96kn6fgFyZhl/YXp6eQ== HTTP/1.1 Continuation
3996	2021-09-24 16:47:06.571342	10.9.23.102	208.91.128.6	285	POST /zLIisQRWZi9/fXMKNg0nKzN/DA15DggB10N6fgFyZhl/YXp6eQ== HTTP/1.1 Continuation
4006	2021-09-24 16:47:31.584345	10.9.23.102	208.91.128.6	273	POST /zLIisQRWZi9/eDkAA0bInx9Rnp6ZXVheXl1fX95 HTTP/1.1 Continuation
4017	2021-09-24 16:47:56.779130	10.9.23.102	208.91.128.6	293	POST /zLIisQRWZi9/Lji+7SoqJQ4lBiwyAHR7KngvHgoPKBhfntkcmJ9eGR6fH0= HTTP/1.1 Continuation
4027	2021-09-24 16:48:21.805873	10.9.23.102	208.91.128.6	289	POST /zLIisQRWZi9/HWwNkCfAdwRPkwFFM50/TT5PF76emV1YX157X1/e0= HTTP/1.1 Continuation


```

POST /zLIisQRWZi9/OQsaDixzHTgtfjMcGypGenpldwF5ehV9f3k= HTTP/1.1
Host: maldivehost.net
Content-Length: 112

Dw8YBxsEGmYFAAEJfR4NqkMmLTyQZDK5KyQmOyRGQglxEBo4Lzk/EyYrMi1h0T8vIyM7IhcNPzsOKjguFvgkLSIiJcXFRgwFAGIIDQUZGBoFD0JF

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:46:15 GMT
Server: Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4
X-Powered-By: PHP/5.6.40
Content-Length: 302
Strict-Transport-Security: ...max-age=15552000...
Connection: close
Content-Type: text/html; charset=UTF-8

```

Further investigation revealed two critical post-compromise actions. Firstly, a DNS query to api.ipify.org was made at 2021-09-24 17:00:04. This service returns the public IP address of the requester, indicating the malware was performing environmental reconnaissance to determine the victim's external network profile, which can inform the attacker's next steps.

dns.flags.response == 0 && ip.src == 10.9.23.102 && dns.qry.name contains "ip"					
No.	Time	Source	Destination	Length	Info
24147	2021-09-24 17:00:04.093354	10.9.23.102	10.9.23.5	73	Standard query 0xc92c A api.ipify.org
25279	2021-09-24 17:00:59.174080	10.9.23.102	10.9.23.5	73	Standard query 0x8eed A api.ipify.org
26756	2021-09-24 17:02:17.477261	10.9.23.102	10.9.23.5	73	Standard query 0x8d97 A api.ipify.org
27836	2021-09-24 17:02:35.839648	10.9.23.102	10.9.23.5	73	Standard query 0x5250 A api.ipify.org

Secondly, SMTP traffic analysis uncovered exfiltration attempts. The attacker sent data from farshin@mailfa.com, with authentication attempts for ho3ein.sharifi@mailfa.com using the encoded password MTM2OTEzNjk= (which decodes from Base64 to 13691369). The transmission of credentials over the network, using compromised mailfa.com accounts, suggests the malware had harvested them from the victim system and was attempting to exfiltrate them to an attacker-controlled mailbox.

smtp					
No.	Time	Source	Destination	Length	Info
28420	2021-09-24 17:02:44.796384	10.9.23.102	185.4.29.135	66	C: AUTH LOGIN
28448	2021-09-24 17:02:45.016897	10.9.23.102	46.16.61.250	64	C: STARTTLS
28450	2021-09-24 17:02:45.017355	185.4.29.135	10.9.23.102	72	S: 334 VXNlcm5hbWU6
28457	2021-09-24 17:02:45.176516	46.16.61.250	10.9.23.102	84	S: 220 2.0.0 Ready to start TLS
28467	2021-09-24 17:02:45.448848	10.9.23.102	185.4.29.135	80	C: User: Zmfyc2hpbkbtYwlsZmEuY29t
28477	2021-09-24 17:02:45.683352	185.4.29.135	10.9.23.102	72	S: 334 UGFzc3dvcmQ6
28480	2021-09-24 17:02:45.698448	185.4.29.135	10.9.23.102	75	S: 220 mail.mailfa.com
28504	2021-09-24 17:02:45.964203	10.9.23.102	185.4.29.135	68	C: Pass: ZGluYVlpdA==
28506	2021-09-24 17:02:45.964344	10.9.23.102	185.4.29.135	70	C: EHLO localhost
28521	2021-09-24 17:02:46.192228	185.4.29.135	10.9.23.102	110	S: 250-mail.mailfa.com SIZE 30000000 AUTH LOGIN
28524	2021-09-24 17:02:46.198191	185.4.29.135	10.9.23.102	75	S: 235 authenticated
28576	2021-09-24 17:02:46.778017	10.9.23.102	185.4.29.135	86	C: MAIL FROM:<farshin@mailfa.com>
28578	2021-09-24 17:02:46.778150	10.9.23.102	185.4.29.135	66	C: AUTH LOGIN
28598	2021-09-24 17:02:47.009894	185.4.29.135	10.9.23.102	72	S: 334 VXNlcm5hbWU6
28602	2021-09-24 17:02:47.031611	185.4.29.135	10.9.23.102	131	S: 550 Your SMTP Service is disable please check
28685	2021-09-24 17:02:47.617861	10.9.23.102	185.4.29.135	92	C: User: aG8zZWlnLnNoYXJpZm1AbWpBpGZhLmNvbQ==
28695	2021-09-24 17:02:47.663931	52.97.201.242	10.9.23.102	165	S: 220 ZR0P278CA0101.outlook.office365.com Microsoft Exchange
28711	2021-09-24 17:02:47.848092	185.4.29.135	10.9.23.102	72	S: 334 UGFzc3dvcmQ6
28742	2021-09-24 17:02:48.252166	10.9.23.102	52.97.201.242	70	C: EHLO localhost
28748	2021-09-24 17:02:48.361956	52.97.201.242	10.9.23.102	165	S: 220 ZR0P278CA0103.outlook.office365.com Microsoft Exchange
28751	2021-09-24 17:02:48.419170	52.97.201.242	10.9.23.102	250	S: 250 ZR0P278CA0101.outlook.office365.com Hello
28763	2021-09-24 17:02:48.611926	10.9.23.102	185.4.29.135	68	C: Pass: MTM2OTEzNjk=

```

220 mail.mailfa.com
EHLO localhost
250-mail.mailfa.com
250-SIZE 30000000
250 AUTH LOGIN
AUTH LOGIN
334 VXNlcm5hbWU6
aG8zZWluLnNoYXJpZm1AbWFPbGZhLnNvbQ==
334 UGFzc3dvcmQ6
MTM2OTEzNjk=
235 authenticated.
MAIL FROM:<ho3ein.sharifi@mailfa.com>
550 Your SMTP Service is disable please check by your mailservice provider.

```

CONCLUSION

The investigation confirmed a multi-stage intrusion initiated when a user executed a malicious macro within chart-1530076591.xls, delivered from the compromised attirenepal.com. This characteristic Advanced Persistent Threat campaign progressed through an orchestrated sequence: retrieving secondary payloads from domains like finejewels.com.au and thietbiagt.com, establishing encrypted C2 channels with infrastructure at survmeter.live and securitybusinpuff.com, and culminating in data exfiltration via maldivehost.net and SMTP.

One of the main challenges encountered during the analysis was examining HTTPs- encrypted data, which concealed the full contents of the secondary payloads and limited visibility of certain indicators within the traffic. This necessitated a heavy reliance on behavioural analysis, including beaconing timing, TLS handshake sequences, and protocol anomalies.

To prevent recurrence, immediate measures should include user training on macro threats and blocking internet-sourced macros by default. Deploying advanced endpoint protection and network monitoring systems is also crucial to detect such behavioural patterns and block the identified IOCs, thereby containing threats before full compromise occurs.

The wider implications for an organisation include potential data breach consequences, significant operational disruption, and severe reputational damage, making proactive investment in security measures both operationally and financially imperative.

APPENDIX

Student Declaration of AI Tool use in this Assessment

Solo Work	S1 - Generative AI tools have not been used for this assessment.	☐
Assisted Work	A1 – Idea Generation and Problem Exploration Used to generate project ideas, explore different approaches to solving a problem, or suggest features for software or systems. Students must critically assess AI-generated suggestions and ensure their own intellectual contributions are central.	☐
	A2 - Planning & Structuring Projects AI may help outline the structure of reports, documentation and projects. The final structure and implementation must be the student's own work.	☐
	A3 – Code Architecture	☐

	AI tools maybe used to help outline code architecture (e.g. suggesting class hierarchies or module breakdowns). The final code structure must be the student's own work.	
	A4 – Research Assistance Used to locate and summarise relevant articles, academic papers, technical documentation, or online resources (e.g. Stack Overflow, GitHub discussions). The interpretation and integration of research into the assignment remain the student's responsibility.	☐
	A5 - Language Refinement Used to check grammar, refine language, improve sentence structure in documentation not code. AI should be used only to provide suggestions for improvement. Students must ensure that the documentation accurately reflects the code and is technically correct.	☐
	A6 – Code Review AI tools can be used to check comments within the code and to suggest improvements to code readability, structure or syntax. AI should be used only to provide suggestions for improvement. Students must ensure that the code accurately reflects their knowledge and is technically correct.	☐
	A7 - Code Generation for Learning Purposes Used to generate example code snippets to understand syntax, explore alternative implementations, or learn new programming paradigms. Students must not submit AI-generated code as their own and must be able to explain how it works.	☐
	A8 - Technical Guidance & Debugging Support AI tools can be used to explain algorithms, programming concepts, or debugging strategies. Students may also help interpret error messages or suggest possible fixes. However, students must write, test, and debug their own code independently and understand all solutions submitted.	☐
	A9 - Testing and Validation Support AI may assist in generating test cases, validating outputs, or suggesting edge cases for software testing. Students are responsible for designing comprehensive test plans and interpreting test results.	☐
	A10 - Data Analysis and Visualization Guidance AI tools can help suggest ways to analyse datasets or visualize results (e.g. recommending chart types or statistical methods). Students must perform the analysis themselves and understand the implications of the results.	☐
	A11 - Other uses not listed above Please specify:	☐

Partnered Work	P1 - Generative AI tool usage has been used integrally for this assessment Students can adopt approaches that are compliant with instructions in the assessment brief. Please Specify: • Research further concepts • Write/generate/troubleshoot scripts to facilitate analysis • Report generation and improvements • Readme report, script crafting.	☒
-----------------------	---	-------------------------------------

Please provide details of AI usage and which elements of the coursework this relates to:
Report improvements, generating display filters for Wireshark analysis.

I understand that the ownership and responsibility for the academic integrity of this submitted assessment falls with me, the student.	☒
I confirm that all details provide above are an accurate description of how AI was used for this assessment.	☒